

MediSecure Telehealth Inc.

Document ID: SEC-POL-026

Version: 1.0

Classification: Internal Use Only

Aligned Frameworks: ISO/IEC 27001:2022 (Controls A.8.8, A.8.13, A.8.22, A.8.32) | ITIL v4 (Release, Change & Disaster Recovery Management)

1. PURPOSE

This policy establishes mandatory operational frameworks, architecture controls, and change-management protocols to protect MediSecure's enterprise networks, patient databases, and intellectual property from the execution, propagation, and business impact of malicious software (malware/ransomware).

2. SCOPE

This policy applies to all production servers, database clusters, network environments, and technical staff members responsible for maintaining MediSecure's infrastructure.

3. POLICY STATEMENTS

3.1 Technical Vulnerability & Patch Management (ISO 27001 A.8.8 & ITIL Release Management)

- **Continuous Vulnerability Assessment:** IT Operations must conduct weekly automated vulnerability scanning across all production environments.
- **Mandatory Patching SLAs:** Upon the discovery or release of a critical vendor patch (e.g., Microsoft, AWS Security Advisories), the patch must be deployed through the CI/CD pipeline for automated stability testing.
- **Enforced Timeline:** Tested critical patches must be pushed to production environments within **72 hours** of public release. Operational or development downtime fears shall not delay critical patch deployment.

3.2 Disaster Recovery & Backup Architecture (ISO 27001 A.8.13 & A.8.22)

- **Network Isolation (Air-Gapping):** All enterprise backup repositories must reside on an entirely separate network subnet, completely isolated by internal firewalls from the primary production environment.
- **Non-Persistent Connectivity:** Backup storage volumes must not remain persistently mapped or connected to active production servers. Backup connections must trigger programmatically (e.g., every 5 hours), transfer data, and terminate access immediately upon completion.

- **Restoration Validation:** IT Operations must conduct mandatory **Bi-Annual Backup Restoration Drills** to mathematically prove data integrity and guarantee the organization can meet its recovery time objectives.

3.3 Strict Infrastructure Change Control (ISO 27001 A.8.32 & ITIL Change Enablement)

- **Zero-Tolerance Manual Adjustments:** No network, firewall, or server configuration modifications may be performed ad-hoc or without audit trails.
 - **Perimeter Restrictions:** Opening network communication vectors to the public internet (including but not limited to Port 3389 - RDP) is strictly classified as a "Normal Change."
 - **Prior Authorization & Tracking:** Such changes require a formal risk assessment, written authorization from the Security Team, active logging of the administrator's identity/timestamp, and continuous surveillance by the SOC.
-

4. EMERGENCY ESCALATION & CRISIS COMMUNICATION (ITIL Practice)

- **Immediate Escalation:** Upon high-confidence SIEM/EDR detection of a malware outbreak, mass file encryption, or active shadow copy deletion, the SOC must initiate the **ITIL Major Incident Protocol**.
- **Automated Out-of-Band Notification:** The incident management platform must leverage automated, out-of-band communication systems to immediately page the SOC Lead, Chief Information Security Officer (CISO), Chief Executive Officer (CEO), and Legal Counsel simultaneously, regardless of the hour, to minimize strategic communication delay.

5. COMPLIANCE & ENFORCEMENT

Failure to log infrastructure modifications, deliberate circumvention of change-management protocols, or unapproved deferral of critical security patches will result in immediate escalation to Internal Audit and human resources for disciplinary actions, up to termination of employment.